October Progress and Project Status

Course: Introduction to Secure Development Practices - Task 1 companion document **Application:** Pinpoint - privacy-first location-sharing app **Period covered:** 1 October - 2 November 2026 - **Prepared:** 2 November 2026

---

1. What the project is

Pinpoint is a full-stack location-sharing application built by a team of six:

Layer	Technology	Location
Primary API	Go (net/http, pgx, JWT, bcrypt)	`backend/cmd/server`, `backend/internal/`
Alternate API	Python / FastAPI (SQLAlchemy, alembic)	`backend/app`, `backend/alembic/`
Android client	Kotlin / Jetpack Compose, MapLibre, Clean Architecture	`mobile/` (`app` + `core:*` + `feature:*`)
Web clients	Vanilla ES-module PWA (nginx) and Leaflet client	`web/`, `backend/web/`
Docs	arc42 + Diataxis + ADRs, Mermaid diagrams	`docs/`

Baseline (Go + Python APIs, Android app, web clients, Docker Compose demo) was defined in the September MVP milestone and re-landed into this repository on 13 October.

---

2. October timeline (from repository history)

Week 1 - 13 October: repository consolidation

- Ported the project baseline and documentation set into the team repository (*Porting from another repo*).
- Task board created: 40 tasks, 5 members x 8 weeks, planned backlog, UML diagram suite.
- Local-development-setup documentation updated through the PR flow (PRs #7, #8, #10, #11) - first use of the team's review/merge process.
- **Result:** a single, shared `main` branch everyone builds on.

Weeks 2-3 - 28-29 October: hardening, conformance, CI, and clients

One dense stretch of work (28 commits), grouped by theme:

Backend security hardening (28 Oct)

- Pattern-based security structure ported and reconciled with the mainline (`services/`, `repositories/`, `middleware/`), plus a new security test suite, security documentation and architecture diagrams.

T01 - repository conformance (28-29 Oct)

- Extracted `store.Repository` interfaces so handlers depend on abstractions;
- Added a PostgreSQL implementation (pgx stdlib, schema bootstrap);
- Wired `DB_DRIVER=memory|postgres` with graceful fallback to memory;
- Added a conformance suite that runs **the same tests against both drivers**;
- Fixed Postgres-vs-memory drift found by the suite (`nowUTC()` microsecond truncation, login-attempt email lowercasing, `sql.NullFloat64` for NULL lat/lon) - *9f35f127*.

CI pipeline (28 Oct)

- Added the `backend-go` job (build/vet/test + Postgres 16 conformance via `TEST_DATABASE_URL`), the `backend` job (ruff, bandit, pip-audit, alembic migrations + pytest against Postgres), the `mobile` job (Android compile + JVM tests) and the `web` job (ES-module syntax checks for `web/public/js/*.js` and `sw.js`).

Android client (28 Oct)

- M1 scaffold: offline maps, privacy-first modular architecture (Clean Architecture modules, MapLibre only inside `core:map`, Retrofit/OkHttp only inside `core:network`, 0 trackers);
- M2 started: `LocationProvider` domain contract;
- Earlier in October: MapLibre coordinate fixed to `org.maplibre.gl:android-sdk:11.5.1` (Maven Central), offline-manager API signature drift fixed, hand-rolled `JsonConverterFactory` replacing an unmaintained converter library.

Web client (28 Oct)

- New modular privacy-first PWA (`web/public`) with offline shell (service worker), compliant tile host (`maps.wikimedia.org` - never OSMF servers, per OSMF usage policy), CSP aligned in `nginx.conf`, and a regression test pinning the tile policy in the Python-served client as well.

Docs & governance (28 Oct)

- Commit conventions documented in `AGENTS.md`; mobile architecture, licensing stance and board progress recorded; ported artifacts reconciled with `AGENTS.md` rules.

Week 4 - 2 November (to date): features, green CI, deployment prep

- **Public self-registration endpoint** (`POST /api/v1/auth/register`) with a shared `issueSession` helper and three fail-closed regression tests; tester seed `user@user.user / user1234` (password meets the 8-char minimum server policy) in memory and Postgres seeds. Login for unknown users stays a generic 401 - never a 404 - so the client cannot enumerate accounts.
- **Mobile combined sign-in/sign-up** (`signInOrSignUp()`): login first, fall back to registration on 401, surface 409 as "*Wrong password for this account*"; offline-first splash -> map; crash reports written to `Downloads/crash_reports/` with a share button; `RouteCalculator` and `SafetyAlerts` added; debug APK built (51.1 MB).
- **CI fully green - run #26, commit `108228dc`: all four jobs pass** (`backend-go` `backend` `web` `mobile`). First all-green run on the repository.
- **Documentation pass:** top-level docs restyled, `docs/PRACTICE_STATUS.md` written.
- **CI fixes:** bandit/ruff double suppression for error-code constants (run green).
- **Deployment prep:** `render.yaml` Blueprint (Dockerfile path corrected), Vercel static deploy path (`web/public/vercel.json` rewrites + `scripts/deploy-vercel.mjs`, REST-based, token from env only), `docs/DEPLOYMENT.md` with verified localhost recipes and credential-scope findings.

---

3. Current project status (2 November 2026)

Working and verified

Area	Evidence
CI green	GitHub Actions run #26 (`108228dc`): backend-go, backend (ruff/bandit/pip-audit/alembic/pytest), web, mobile - all
Go API on localhost	`GET :8000/health` -> healthy; tester login OK; register -> 409 duplicate -> login flow OK; SPA fallback serves the web client
Python API on localhost	`GET :8001/api/v1/health` -> ok; register -> 201; login -> 200 (SQLite + in-memory rate limit, no external services needed)
Go test suite	`go build ./... && go vet ./... && go test ./...` clean, incl. fail-closed register tests and Postgres conformance (CI)
Python test suite	141 passed, 1 skipped locally (incl. known pre-existing flake `test_session_limit_revokes_oldest`, unrelated)
Android APK	`mobile/app/build/outputs/apk/debug/app-debug.apk` - 51.1 MB, JDK 17 build
Security baseline	server-side enforcement only; 0 trackers; no secrets in repo; OSM/ODbL attribution visible; AES-GCM session storage; CSP tile allow-list
Supabase project	`https://skyvzxxquupylpczhznw.supabase.co` verified live: PostgREST 200 (Postgres 14.18), GoTrue healthy
Task 1 deliverables	`docs/task1/owasp-top10-and-security-requirements.md` + this document

In progress / prepared, awaiting credentials

Cloud deployment is fully prepared but cannot complete without credentials held only by the team (never committed to the repository):

Item	State	What is needed
Render Blueprint (`render.yaml`)	Validated; Dockerfile path fixed	Render API key (`rnd_...`) *or* manual "New -> Blueprint" run; then set `DATABASE_URL`, `SESSION_SECRET`, `REDIS_URL`
Supabase PostgreSQL	Project verified reachable	Connection string (Session pooler, port 6543) from Dashboard -> Settings -> Database; then run `alembic upgrade head`
Vercel web client	Deploy script + `vercel.json` ready, `node --check` passes	The tested `vck_...` key is **read-only** (403 on project/deployment creation) - needs an account PAT with *Create Deployment*, or a manual dashboard import
Render Go API live check	Blocked on the above	`GET https://pinpoint-go-api.onrender.com/health` (currently 404 - service not created yet)

Known open findings

- **Dependabot: 20 open vulnerabilities (8 critical, 4 high, 8 moderate)** on the default branch - tracked as security requirement **SR-8** in the Task 1 security document; remediation is a per-PR update backlog, not yet started.
- Actions workflows pinned by major tag (`@v4`) rather than commit SHA; release APK not yet signed with a release key (noted under A08/SR-10).

- `docker compose up --build` full-stack demo not run locally (no Docker on the machine); CI covers the individual services instead.
- Known pre-existing test flake: `test_session_limit_revokes_oldest` (passes alone, occasionally fails in a full local run - verified pre-existing on pristine `origin/main`).

---

4. Where the project stands against the task board

Board area	Status
T01 repository conformance (interfaces + PostgreSQL + dual-driver suite)	Landed (28-29 Oct)
Backend security hardening + test suite + docs/diagrams	Landed (28 Oct)
CI pipeline (Go/Postgres, Python, Android, web)	Landed and green (28 Oct -> 2 Nov)
Android M1 (scaffold, offline maps, privacy architecture)	Landed (28 Oct)
Android M2 (LocationProvider, route calculator, safety alerts, combined auth, crash reports)	Started / in progress
Privacy-first web client with compliant tiles + offline shell	Landed (28 Oct)
Authentication UX (combined sign-in/sign-up, tester account, fail-closed tests)	Landed (2 Nov)
Cloud deployment (Render + Supabase + Vercel)	Prepared, blocked on team credentials
Dependency-vulnerability remediation (SR-8)	Open (20 alerts)
Release signing / production hardening	Not started

---

5. Immediate next steps

1. **Team credentials for deployment** (see Section 3): Supabase Session-pooler connection string, deploy-capable Vercel token, Render API key - then migrations run, Blueprint is created, and `https://pinpoint-go-api.onrender.com/health` is verified end-to-end.
2. **Triage the 20 Dependabot alerts** (SR-8) - criticals first, one PR per component family.
3. **Continue Android M2** (route calculator + safety alerts integration, combined-auth flow behind the new register endpoint).
4. **Task 1 submission by 4 November 2026, 23:00** - both documents in `docs/task1/`.